PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation d'Active Directory

03-480 ANSSI - Recommandations de sécurité relatives à Active Directory — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La forêt constitue la véritable frontière d'isolation administrative car l'élévation de privilèges d'un administrateur de domaine vers la forêt reste techniquement possible.
2. L'utilisation d'un RODC avec chiffrement et cache limité est préconisée pour les sites dont la sécurité physique n'est pas garantie.
3. La protection des comptes d'administration est assurée par l'objet AdminSDHolder qui réapplique périodiquement un modèle de sécurité de référence.

Priorisation des recommandations

Niveau de priorité	Objectif de protection
Priorité 1	protection contre l'exploitation de **vulnérabilités** pouvant compromettre l'AD
Priorité 2	protection contre les **accès non autorisés**
Priorité 3	protection portant sur l'**intégrité** et la **non-divulgation** des données
Priorité 4	périmètre **moins critique** ou **complexité de mise en œuvre** plus élevée

Les partitions de l'annuaire

4 partitions (données du domaine, configuration, schéma, application), répliquées entre tous les **DC en écriture**.

Prérequis à la sécurisation

Notion	À retenir
Architecture et réplication	Ports de réplication **fixés** (obligatoire derrière un pare-feu). Topologie KCC conservée tant que **(domaines + 1) × sites² < 100 000**, sinon réduire les liens ou planifier le KCC. DC peu sûr : **RODC** (disques chiffrés, cache limité aux comptes **sans privilège**), DC en écriture dans le site sûr le plus proche.
Santé DC et accès distant	Journal sécurité : **1 Go** via GPO. Audit (réussite/échec) activé. Collecte en **format natif Microsoft**. Accès distant : postes dédiés, **WinRM en HTTPS**. Pas de logiciel tiers (antivirus).

Éléments de sécurité de l'annuaire

Notion	À retenir
Niveau, schéma, approbation	Viser le **niveau fonctionnel** le plus haut. Extensions de schéma : **OID** enregistrés et validés **hors production**. Approbation : **authentification sélective** privilégiée et **filtrage des SIDs** activé.
OU, FSMO, GPO	OU : simples, pour **délégation** ou **GPO**. FSMO : tous sur **un même DC** en mono-domaine, **PDC** sur machine robuste en multi-domaines. GPO : **nommage** précis, **nombre limité**, **héritage** limité.
Groupes et accès	Surveiller **ACL AdminSDHolder**. Restreindre **comptes administrateurs**. Groupes **Opérateurs** vides. Délégation : **moindre pouvoir**. Maîtriser **ticket Kerberos** (réduire groupes et **SID History**).

Gestion des comptes

Notion	À retenir
Authentification et catégorisation	Niveau **LAN Manager** au plus haut (au minimum **3**, puis **5**). Cache de domaine : **0** sur serveurs, **1** sur postes. `adminCount` = **1** uniquement pour groupes d'administration protégés.
Scripts, mots de passe et inactifs	Pas de mot de passe **en clair** dans un script (Kerberos ou compte de service). Complexité et expiration pour **tous** les comptes. Inactifs : désactivés, **droits retirés**, déplacés en **UO dédiée**.

Mesures de contrôle et d'audit

- ☐ **Sensibiliser** et **former** les administrateurs ; **roulement des tâches** pour détecter négligence ou malveillance.
- ☐ **Ressources** expertes suffisantes pour la continuité en crise.
- ☐ **Revue régulière** des droits des comptes privilégiés ; **audits** réguliers, idéalement par un **PASSI**.

Pièges et confusions

- ⚠ Croire que la frontière de domaine est la véritable limite de sécurité alors qu'il s'agit de la frontière de forêt.
- ⚠ Se fier à la seule désactivation d'un compte sans lui retirer ses droits et privilèges.
- ⚠ Installer un logiciel tiers comme un antivirus sur un contrôleur de domaine pour augmenter la sécurité alors que cela augmente sa surface d'attaque.
- ⚠ Considérer qu'un compte avec l'attribut adminCount à 1 n'est pas soumis à la protection systématique de ses permissions.

Sigles et définitions

Active Directory, AD	annuaire centralisant les informations relatives aux utilisateurs et aux ressources d'une entreprise et fournissant des mécanismes d'identification et d'authentification
Contrôleur de domaine, DC	serveur qui héberge une copie de l'annuaire
Catalogue global	DC détenant en plus une partie des informations des autres domaines de la forêt
RODC	contrôleur de domaine en lecture seule possédant une copie partielle et non modifiable de l'annuaire
KCC, Knowledge Consistency Checker	service qui génère dynamiquement la topologie de réplication entre contrôleurs de domaine
Forêt	groupe de plusieurs domaines constituant la frontière réelle d'isolation administrative
AdminSDHolder	objet qui protège périodiquement les ACL des comptes et groupes d'administration protégés
adminCount	attribut positionné à 1 marquant un compte comme membre d'un groupe d'administration protégé

Auto-test

1. Quelle est la véritable limite de sécurité entre les domaines d'une même forêt ?
2. Que doit-on faire impérativement lors de la désactivation d'un compte ?
3. Quel est l'impact de l'installation d'un antivirus sur un contrôleur de domaine ?
4. Quelle valeur doit prendre l'attribut adminCount pour un compte protégé ?
5. Quel service génère la topologie de réplication ?

Réponses : **1.** La frontière de forêt · **2.** Lui retirer ses droits et privilèges · **3.** Augmentation de la surface d'attaque · **4.** 1 · **5.** Le KCC

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.